CYBERSECURITY ACADEMY • LEARNING OBJECTIVES

THE TABLETOP

A beginner-friendly guide to designing, running, and evaluating a cybersecurity tabletop exercise

Contents

1 Technical 2

1-1 How do you design scenario injects that test specific organizational capabilities, not general knowledge? . . . 2

1-2 How do you map a tabletop scenario to the capabilities being evaluated before writing a single inject? . . . 3

1-3 How do you define evaluation criteria for each inject that can be applied objectively by a facilitator? . . . 3

2 Conceptual 4

2-1 What is the difference between an exercise and a meeting: injects, decisions, and gaps? . 4

2-2 Why does facilitation neutrality determine whether findings are useful or comfortable? . 4

2-3 How do you convert exercise observations into findings that are specific enough to fix? . 5

3 Transversal 5

3-1 How do you design for stress, knowing that scenarios that are too easy produce no findings? 5

3-2 How do you write for another facilitator so that every artifact works without you in the room? . . . 6

3-3 Why are findings without owners and deadlines not really findings? . . . 6

4 Worked Mini-Exercise: From Inject to Finding 7

5 Exam and Quiz Preparation 7

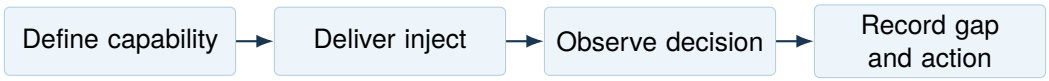
6 MedDefense-specific Regulatory and Supply-Chain Notes 8

7 Quick Exercise Deliverable Checklist 8

8 References and Recommended Reading 9

The exercise in one minute

A **tabletop exercise (TTX)** is a guided simulation in which people explain and make decisions about a fictional incident. It tests **coordination**, **responsibilities**, **communication**, **and judgment**, not whether they can operate technical tools. Here, Nexus Patient Scheduling is compromised. MedDefense depends on its service at three sites, processing about **3,500 appointments each week** through an Epic integration using HL7 FHIR APIs.



1. Technical

What this section teaches

Design the exercise *backwards* from the capabilities to be tested: first decide what the team must demonstrate; then write a scenario event that demands a decision; finally define what the evaluator must observe.

1-1. How do you design scenario injects that test specific organizational capabilities, not general knowledge?

An **inject** is a new piece of scenario information given to participants during the exercise: an email, phone call, vendor update, patient complaint, or simulated news report. A good inject forces a **decision or action**. It should not simply ask participants to define a term.

Anatomy of an inject: record its ID, exercise time, sender, recipient, exact message, capability tested, expected decision, facilitator follow-up, and evidence to capture. *Trigger* and *expected result* are different: the vendor warning is the trigger; the participant's documented escalation is the result.

How to write one: (1) choose a capability, (2) invent a credible change in the situation, (3) remove one piece of certainty, (4) force a choice between realistic options, and (5) decide how you will score the choice. A quiz question such as "What does PHI stand for?" tests memory, not MedDefense's ability to manage an incident.

Start with a capability, such as escalation, clinical continuity, vendor coordination, or breach assessment. Create an event that puts that capability under pressure. Write what participants receive, who receives it, what decision is expected, and what evidence the facilitator should record.

Example: MedDefense

Inject: "Nexus reports suspicious access to its administrator account. It cannot confirm whether appointment data was exported. Your scheduling system is still working."
Test: Can security, legal, and clinical leadership decide who owns the response, what evidence to request, and whether any connection must be restricted? This is better than asking "What is incident response?"

1-2. How do you map a tabletop scenario to the capabilities being evaluated before writing a single inject?

Why map first? Without an objective, an inject might be dramatic but irrelevant. A mapping table creates *traceability*: each inject must test at least one stated objective, and each important objective must have a way to be observed. If an inject tests nothing, remove or rewrite it.

First list the capabilities the organization needs to demonstrate. For each one, define the **objective**, the roles involved, and what successful performance looks like. Only then create injects that reveal whether the team can meet those objectives. This avoids dramatic events that test nothing useful.

Capability	Exercise objective	Possible inject
Escalation	Name an incident lead and notify decision-makers	Vendor announces account compromise
Clinical continuity	Protect patient care while limiting exposure	Scheduling becomes unreliable at all three sites
Third-party coordination	Obtain vendor facts and invoke agreed contacts	Nexus provides conflicting updates
Legal assessment	Assess PHI exposure and notification duties	Evidence suggests possible data export
Communications	Approve consistent internal and external messaging	Reporter asks for confirmation

Key takeaway

Capability → objective → inject → observable evidence. Keep this mapping for every inject.

1-3. How do you define evaluation criteria for each inject that can be applied objectively by a facilitator?

Evaluation versus facilitation: The facilitator delivers the event and asks neutral questions; the evaluator records and scores demonstrated actions against a rubric written *before* the session. One person can perform both jobs in a small exercise, but the tasks are distinct.

Evaluation criteria should describe **observable behavior**, not personal impressions. Avoid "the team communicated well." Instead, identify the specific action, responsible role, output, and (if appropriate) an exercise time limit. The facilitator then records **what was actually said or decided**.

Example: MedDefense

Inject: Nexus reports possible exposure of patient appointment records.
Pass criteria: Participants assign an incident owner; involve legal/privacy and the clinical lead; request details on affected data, patients, timeframe, and protections; document a provisional decision and next review time.
Partial: Some actions occur, but ownership or documentation is missing.
Gap: No one accepts ownership or decides the next step.

A useful scoring sheet has columns for **inject ID, expected action, observed action, evidence, rating, and notes**. Scores should follow the prewritten rubric, not the facilitator's opinion.

2. Conceptual

What this section teaches

A tabletop is an *assessment of organizational behavior*, not a policy lecture. The facilitator creates fair conditions and the evaluator records evidence, even when the result is uncomfortable.

2-1. What is the difference between an exercise and a meeting: injects, decisions, and gaps?

A **discussion-based tabletop** normally does not involve changing production systems or executing real containment commands. Participants *describe* what they would do and state decisions in their assigned roles. The controller can simulate outcomes. This differs from an operational drill, where people demonstrate actions on tools or systems.

A **meeting** often shares information, discusses plans, or teaches procedures. A **tabletop exercise** presents evolving, incomplete information and requires participants to make decisions in their real organizational roles. Those decisions are compared with expected capabilities to expose gaps.

Example: MedDefense

Meeting: "Let's review our vendor incident-response policy."
Exercise: "The vendor might be compromised, the clinical director wants scheduling kept online, and legal has insufficient facts. Who decides what happens in the next 15 minutes?"

The exercise is successful if it produces **testable observations**, even when participants struggle. A comfortable discussion with no recorded gaps is not evidence that the organization is ready.

2-2. Why does facilitation neutrality determine whether findings are useful or comfortable?

Common bias traps: leading questions, revealing a future inject, silently supplying missing facts, changing scoring criteria midway, or treating senior leaders more leniently. Each can hide a gap. Ask every group the same factual follow-ups where possible, allow participants to disagree, and document the disagreement rather than choosing for them.

A **neutral facilitator** presents facts, asks clarifying questions, controls the pace, and records responses without suggesting the "right" answer. If they rescue participants, explain the policy at the critical moment, or praise an unsupported decision, they change the result of the test.

Ask: *"Who has authority to make that decision?"* or *"What evidence supports your choice?"* Do not say: *"You should call legal first."* If someone is stuck, record that as an observation and continue according to the facilitator guide.

Neutrality does not mean ignoring safety, disrespect, or a serious misunderstanding of the exercise rules. The facilitator can enforce boundaries without coaching the incident response.

2-3. How do you convert exercise observations into findings that are specific enough to fix?

Observation is not yet a finding. "Nobody answered the vendor call" is an observation. To become a finding, compare it to the expected procedure, identify the plausible failure (for example, no after-hours vendor contact owner), describe the operational consequence, and specify a fix. Separate verified evidence from suspected causes; do not claim a policy is missing without checking it.

A good finding connects **what happened**, **what should have happened**, **why it matters**, and **what must change**. A vague statement like "communication needs improvement" gives no one a clear task.

Example: MedDefense

Observation: After the second Nexus update, security and clinical leadership each assumed the other would approve restricting the Epic integration. No decision was recorded.
Finding: The third-party incident procedure does not identify a decision-maker for restricting critical clinical integrations.
Risk: Delayed containment or unnecessary interruption of patient scheduling.
Corrective action: Define decision authority and a clinical safety escalation path, then validate them in a follow-up exercise. Assign an owner and due date.

Use an **After-Action Report/Improvement Plan (AAR/IP)** to capture strengths, gaps, corrective actions, owners, and target dates. Separate what participants *demonstrated* from assumptions about what they might do in a live incident.

3. Transversal

What this section teaches

An exercise is useful only if it creates realistic choices, can be run consistently by someone else, and leads to tracked improvements after it ends.

3-1. How do you design for stress, knowing that scenarios that are too easy produce no findings?

Three sources of useful stress: a *time limit* (leadership needs a status update in ten exercise minutes), *uncertainty* (Nexus cannot yet say which records were accessed), and *competing priorities* (containment versus uninterrupted patient scheduling). Pressure should rise in stages so evaluators can see how decisions change with new evidence. Never present fictional facts as real incidents or force a choice for which no defensible answer exists.

Create **realistic decision pressure**, not confusion for its own sake. Introduce incomplete facts, time limits, conflicting priorities, and later updates that challenge earlier decisions. Pressure should reveal weaknesses in escalation, risk acceptance, patient safety, and coordination.

Example: MedDefense

Round 1: Nexus detects suspicious administrator activity; no outage yet.
Round 2: Some appointments appear duplicated and the three sites report delays.

Round 3: Nexus cannot rule out exposure of patient information; a journalist requests comment.
Round 4: Clinical leadership argues that disconnecting Nexus could disrupt urgent appointments.

Escalate the challenge gradually, allow meaningful choices, and provide enough context to make a defensible decision. Do not invent arbitrary "gotchas" that no team could handle. Participants should be evaluated on their **decision process**, not on predicting facts they were never told.

3-2. How do you write for another facilitator so that every artifact works without you in the room?

Think of the facilitator packet as a reproducible recipe. Specify the trigger for each inject (time-based or decision-based), exactly who sees it, which facts the facilitator may reveal, optional prompts if the discussion stalls, what counts as a decision, and when to move on. Put expected answers and scoring notes in facilitator-only documents, not the participant briefing.

Every part must be usable by someone who did not design the exercise. Prepare a **facilitator guide** with the scenario scope, objectives, roles, ground rules, timeline, exact inject text, delivery method, expected discussion, follow-up prompts, evaluation criteria, and instructions for what happens if participants respond unexpectedly.

Also supply a **participant briefing**, **inject cards or a master scenario events list (MSEL)**, **evaluator sheets**, **decision log**, and **AAR/IP template**. Clearly distinguish *exercise time* from real clock time, and label every simulated message as exercise material.

Key takeaway

Reproducibility test: Could another facilitator deliver Inject 3 at the correct point, ask only permitted questions, record the decision, and score it consistently? If not, the guide needs more detail.

3-3. Why are findings without owners and deadlines not really findings?

Follow-through matters more than the score. An action should be specific, measurable, practical, relevant to the gap, and time-bound. "Improve communications" fails this test; "publish an approved vendor escalation list, validate the phone numbers, and retest it within 30 days" can be verified. Record status (open, in progress, verified, closed) and retain evidence of the retest.

An observation becomes useful only when somebody is **accountable for corrective action**. Each improvement item needs a named role or owner, a concrete deliverable, a due date, and a way to verify completion. Otherwise it may be forgotten after the debrief.

Gap	Action / proof of completion	Owner	Due date
Unclear integration shutdown authority	Update playbook; approve escalation matrix; test it	Incident response lead	30 days after exercise
Inconsistent vendor updates	Set vendor update cadence and required information checklist	Vendor risk owner	21 days after exercise
Unclear PHI assessment workflow	Document legal/privacy decision path and record-keeping checklist	Privacy/legal lead	30 days after exercise

These example dates are **proposed exercise improvement targets**, not regulatory deadlines. Review progress until actions are complete and retested.

4. Worked Mini-Exercise: From Inject to Finding

This fictional example ties the nine objectives together. It is a **practice example**, not a claim about what really happened at MedDefense.

Scenario inject and expected behavior

Inject ID: NEX-03. **Exercise time:** 09:20. **Audience:** incident lead, clinical director, legal/privacy, vendor contact.
Message: "Nexus reports that appointment records may have been accessed. The API link to Epic is operating. Two hospitals report mismatched appointment times. Nexus recommends maintaining the link while it investigates."
Capability: coordinated containment and clinical continuity.
Question: "Who decides whether to restrict the integration, what facts do you need, and how will clinical operations continue?"

What an evaluator looks for:

1. Participants name the accountable decision-maker and consult the relevant clinical and security roles.
2. They compare the risk of continued access with the patient-care impact of disruption.
3. They ask Nexus for a timeline, indicators, affected records, API access scope, and containment options.
4. They select a documented temporary action, fallback scheduling process, owner, and reassessment time.

Sample result: The group discussed both risks but no one accepted authority to approve a restricted connection. **Finding:** decision authority for clinical integrations is unclear. **Improvement:** publish and test an escalation/approval matrix, with an assigned owner and due date. This sequence illustrates *inject → observed action → evaluation → finding → verified improvement.*

5. Exam and Quiz Preparation

Remember these distinctions:

Term	What it means in this project
Capability	Organizational function being tested (e.g., clinical continuity).
Objective	Specific capability outcome the exercise intends to evaluate.
Inject	New simulated information requiring participant action or a decision.
MSEL	Master Scenario Events List: inject sequence, timing, delivery, and control notes.
Evaluation criterion	Observable, pre-agreed standard for judging responses.
Observation	What participants actually said, decided, or failed to do.
Finding	Evidence-linked gap, its consequence, and necessary correction.
AAR/IP	After-Action Report/Improvement Plan: results and tracked improvements.

Practice questions (try answering without notes):

1. Why is "What does HIPAA mean?" a weak tabletop inject?
   Answer: it tests recall rather than a decision or organizational capability.
2. A facilitator tells participants to call legal before they decide. What went wrong?
   Answer: the facilitator coached the response, so the outcome is less valid evidence of readiness.
3. The team says it would isolate Nexus immediately. Is this automatically a pass?
   Answer: no. Evaluate authority, patient-care consequences, supporting facts, fallback arrangements, and the written rubric.
4. Is an outage automatically a reportable HIPAA breach?
   Answer: no. Assess whether unsecured PHI was involved in a breach under the applicable rule; preserve the reasoning and evidence.
5. Why is "Improve vendor communications" an incomplete corrective action?
   Answer: it has no measurable deliverable, accountable owner, deadline, or verification method.

6. MedDefense-specific Regulatory and Supply-Chain Notes

- **Supply chain:** A third-party compromise can affect MedDefense even if its own servers were not initially attacked. Test vendor communication, contractual rights, fallback operations, evidence requests, and risk decisions. See NIST SP 800-161 Rev. 1 Update 1.
- **PHI is not automatically breached:** A vendor incident or scheduling outage does not by itself prove reportable disclosure. Legal/privacy must assess the facts, the nature of the information, and applicable HIPAA requirements.
- **HIPAA timelines:** When a business associate discovers a breach of unsecured PHI, HIPAA generally requires it to notify the covered entity *without unreasonable delay* and no later than **60 calendar days**. A business associate agreement may require faster notice. Covered-entity notification rules are distinct and depend on the incident and affected individuals; the threshold of 500 concerns notification routes and timing, not the weekly appointment volume.
- **Clinical safety:** Containment decisions must account for patient care and workable manual scheduling alternatives, not only technical risk.

7. Quick Exercise Deliverable Checklist

- Capabilities, objectives, roles, and scenario assumptions documented
- Inject sequence and facilitator-only instructions prepared
- Objective evaluator criteria and decision log ready
- Participant briefing and exercise boundaries defined
- After-action findings linked to evidence, owners, dates, and retests

8. References and Recommended Reading

1. CISA, *Tabletop Exercise Packages (CTEP)*: https://www.cisa.gov/resources-tools/resources/cisa-tabletop-exercise-packages
2. FEMA, *Homeland Security Exercise and Evaluation Program (HSEEP)*: https://preptoolkit.fema.gov/web/hseep-resources
3. NIST, *SP 800-161 Rev. 1 Update 1, Cybersecurity Supply Chain Risk Management*: https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final
4. CISA, *Defending Against Software Supply Chain Attacks*: https://www.cisa.gov/resources-tools/resources/defending-against-software-supply-chain-attacks
5. HHS, *HIPAA Breach Notification Rule*: https://www.hhs.gov/hipaa/for-professionals/breach-notification/index.html
6. HHS, *Business Associate Contracts*: https://www.hhs.gov/hipaa/for-professionals/covered-entities/sample-business-associate-agreement-provisions/index.html